
Dr. Pooja's Physio - Signed-Out Visitor Test Plan

What a stranger sees, what they may buy, and what must never be reachable

Role

Signed-Out Visitor

Document version

1.0

Audience

A tester checking this role end to end

Environment

Throwaway Supabase project · Razorpay test mode · npm run dev

Read first

Section 1 - who this is, and what has to exist before you start

Contents

1. Who this is, and what must exist first
2. The eight pages
3. What the catalogue shows a stranger
4. What a visitor may buy
5. Registering without booking
6. The public doors, knocked on
7. Where a visitor is sent
8. Across every page
9. Sign-off

1. Who this is, and what must exist first

The account. None. This is a stranger: somebody who has never used this clinic, arriving on the marketing site with no session cookie at all. They are the largest group of people who will ever look at this product, and the only one with nothing to sign in with.

Three questions this document answers. What a visitor *sees*; what they may *buy*; and what must never be *reachable* without an account. The third is where the P0s are - every public door is a door somebody will knock on.

Use a private window throughout. Running any of this in a window where you are signed in sends your cookie and proves nothing. Every step here assumes no session; where a step needs one, it says so and tells you to use a second browser.

1.1 Before you start

A visitor sees whatever the clinic has published, so this plan needs a clinic that has published something.

Must exist	Set up by
Three treatment categories, priced and active, at least two featured	Master Admin
One with an uploaded, positioned cover image	Master Admin
Home visits on , with a service area covering <code>560038</code> at ₹150	Master Admin
One single-visit home package, and one multi-visit one	Master Admin
Two approved therapists visible on <code>/team</code> , one hidden	Master Admin
Testimonials, FAQs and the mission bands populated	Master Admin
A partner hospital with a referral code	Master Admin
Razorpay in test mode	whoever set the environment up

The prices this plan quotes assume `QA Back & Spine Care` at **₹1,999 / 60 min** and a single home visit at **₹2,499** plus **₹150** travel.

1.2 How to record a result

Mark every step **Pass**, **Fail**, **Blocked** or **N/A**. Raise a failure with: the step id, what you did, what you expected, what happened, a screenshot, any console error in full, how many times out of how many it reproduced, and **which browser and window** you used - private or not, since that is the whole premise here.

Severity. P0 - money, clinical data or access control is wrong: stop and report. **P1** - a main journey is broken with no workaround. **P2** - wrong with a workaround. **P3** - cosmetic.

1.3 Calling a route without a terminal

Several steps knock on a public door. **Use a private window with no session.** Press **F12**, open **Console**, paste and press Enter:

```
const r = await fetch("/api/some/route", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify({ some: "value" }),
});
({ status: r.status, body: await r.text() });
```

Confirm you are anonymous first - run `document.cookie` and check there is no Supabase session in it. Never paste the URL in the address bar: that sends a GET, these are POSTs, and you will get 405 and think you found something.

2. The eight pages

VI-01 - Every page exists and is one template · P1

Do this. Open each in turn and read it top to bottom.

Page	
/	☐
/conditions	☐
/how-it-works	☐
/home-visit	☐
/team	☐
/mission	☐
/faq	☐
/hospitals	☐

Expect

- Each opens with a **hero: a photograph, one headline, one sentence and up to two calls to action.**
- Each **ends the same way** - seven of the eight on the same closing band, `/hospitals` on its referral form instead. Wherever a visitor stops reading, the next step is in the same place.
- They read as **one site**, not seven. Eight bespoke heroes and eight different closing blocks is what this replaced: **P2** if one page clearly has its own layout.

VI-02 - The photography is load-bearing · P2

Do this. Blur your eyes, or open each page's images alone.

Expect

- **You can tell what each page is about from the pictures.**
- **Every photograph has a device in frame** - a laptop, tablet or phone - **except the two home-visit ones**, which show hands-on treatment. This clinic sells video consultations; a site of clinic photography

reads as a walk-in practice, which is the opposite of what it is. **A cropped-off laptop is a P2**, and it is the commonest way this regresses: the source has the device low in frame and a centre crop loses it.

- **Every photograph shows a face**, visible and glad to be there - except the clinician reading a scan, who is concentrating, because somebody grinning at an X-ray is the opposite of reassuring. **A back of a head, a torso-only frame or an empty desk is a P2**.
- No image is broken, and none is a remote URL.

VI-03 - One idea per band, and short · P3

Expect. No band carries two ideas, and no slot carries a paragraph. A hero subtitle runs to about a dozen words; a section's single lede to about nine, or is dropped entirely when the heading already says it; a card's body to ten.

A lede that restates its heading is worse than none. If you find yourself skimming, that is the finding: report the band.

VI-04 - The section rail and the scroll arrow · P1

Do this. On each page with a section rail:

1. Tap each rail entry.
2. Use the bottom-right scroll arrow repeatedly, from the top.

Expect

- Every rail entry lands on a section that **actually rendered**. Several bands are conditional on the catalogue, so an entry for a band that is not there is a **P1**.
- The arrow walks the sections **top to bottom, in order**. An entry out of order sends it **backwards**, which is the tell.

VI-05 - The Explore band ends on booking · P2

Do this. Scroll to the "where to go next" grid on `/` and then on each of the other six.

Expect

- Every one of them ends on **booking**, not on another page to read. A band still answering "what now?" with "here is more to look at" is the thing the site's whole shape is against: **P2**.
- The page you are on is **absent** from its own grid.
- The rows **square up** - no single tile left alone beside two empty cells. Count them: with Home Visit switched off there is one fewer, so the layout has to work at both counts.

3. What the catalogue shows a stranger

VI-06 - Four conditions on the home page, the rest a tap away · P2

Do this. Open `/`, then `/conditions`.

Expect

- `/` leads with the **featured** conditions, up to **four**, with a control leading on to `/conditions`.
- `/conditions` shows **everything**.

- With nothing featured, `/` falls back to the **first four** - an empty band reads as the clinic having shut.
- **Nothing on either page rearranges itself when a booking lands.** There is no "most popular" ordering; which four lead is somebody's decision.

VI-07 - There is no programme catalogue, anywhere · P0

Do this. Search `/` and `/conditions` - the rendered page and the page source - for a **multi-session programme** and its price.

Expect

- **Nothing.** The public pages carry treatment **categories** and their **consultation price**, and no programme price list at all.
- `/home-visit` shows **single visits only**. The multi-visit package is not on it.
- **A programme price on a public page is a P0.** Treatment volume is never sold before an assessment: a programme comes from a clinician's recommendation, and a patient must not be able to shop from a price list.
- There is **no setting anywhere** that brings one back. A toggle somebody can flip is not the rule being gone.

VI-08 - The card, and the dialog behind it · P2

Do this. On `/conditions`, tap a condition's card body, then close it and tap **Book**.

Expect

- The **card body opens a detail dialog**; the **Book** link is a separate control **below** it, not nested inside it.
- In the dialog, the photograph gets the **full width with nothing on top of it**, and the heading sits on its own band **below**. Text over a photograph needs a scrim dark enough for any image: **P2** if the heading is over the picture.
- The card is **4:3**, the dialog is **16:9**, and the subject is **correctly placed in both. A head cut off in one of the two is a P2.**
- A condition with **no** cover shows a **tinted panel at the same height** with an illustration - it must look like one whose photo has not been chosen yet, never like one whose image failed to load.
- Escape closes the dialog, Tab is trapped inside it, focus returns to the card, and the page behind does not scroll.

VI-09 - `/team` · P1

Do this. Open `/team`.

Expect

- The two visible therapists, with their bio, languages, qualification and specialism.
- **The hidden one is absent.** So is any suspended or unapproved one - check by having the Master Admin suspend one in another browser and reloading: they come off **immediately**, not five minutes later when a cache lapses. **A suspended clinician still on the public page is a P2.**
- **No therapist's phone number or email address is on this page.**
- A rating renders only if the admin has left ratings public.
- Tapping a therapist opens a popup, with the same dialog behaviour as `VI-08`.

VI-10 - /mission · P2

Expect

- The mission and the vision, in full.
- The **promises** band and the **limits** band. With a band's rows all switched off, **the band and its rail entry both disappear** - a rail entry pointing at a section that did not render is VI-04's bug.
- **No heading counts the cards.** "Four things, every patient" over three cards is a number nobody remembered to change: **P3**.
- On /, the mission band gives the mission and vision **in full** and the promises as **titles only**, each linking into /mission. The two pages must quote the **same** sentence - a home page teasing a different wording is a **P2**.

VI-11 - /faq and the testimonials · P3

Expect

- The FAQs, in the admin's order.
- Testimonials on / and /mission, with a photo or the person's initial - never a generic silhouette, which is a worse signal than no photo.
- The public rating summary is the **only** place a real number is quoted.

VI-12 - /home-visit when the switch is off · P1

Do this. Have the Master Admin switch home visits **off**. Then, as a visitor:

Try	Expect
Open /home-visit	404
Look in the header nav	Home Visit is gone
Look in the footer	Gone
Look in /'s connector grid	Gone
Look in the "where to go next" strip on the other pages	Gone

A link to a 404 is a P1. Switch it back on.

4. What a visitor may buy

VI-13 - Book and register on one screen · P0

This is the commonest real path into the product: a stranger books, registers and pays without ever having had an account.

Do this

1. From /conditions, tap **Book Assessment** on QA Back & Spine Care.
2. **Step 1:** read what is pre-selected before changing anything - a date, an hour, a language, and the detected timezone stated on screen.
3. Choose tomorrow at **4:00 PM**.

4. **Step 2:** fill in a new patient's details and tick the telehealth consent.
5. **Step 3:** read the whole screen and note the figure on the button.
6. Pay with the Razorpay test card.

Expect

- Step 3: **no hour inside the 12-hour lead time is offered at all**, and no half-hour anywhere. Slots start on the hour.
- Step 4: **the account is created and you are signed in immediately**. There is **no "check your email" step** anywhere - email confirmation is off in this product by design. **A confirm-your-address step is a P1**, and means the project's setting was turned back on.
- Step 5: **the figure on the button is the figure the Razorpay sheet opens with. A screen that quotes one price and charges another is a P0** - it is the single worst outcome a payment screen can produce.
- Step 6 lands on a **confirmation with one next step**, not on a blank screen and not on a balance.
- Paying **approves the patient on the attempt**, so they land in their dashboard rather than on a waiting screen.

VI-14 - Abandon checkout, and come back · P1

Do this. Start the same flow with a new address, get as far as the Razorpay sheet, and **close it** without paying. Then find your way back in.

Expect

- The account **exists** and you can sign in.
- The session is there as **unpaid / pending**, not lost.
- You are **in your dashboard**, not bounced to a waiting screen - somebody who genuinely tried to pay has already shown intent.

VI-15 - A first-session offer, quoted and charged the same · P0

With the offer on at **₹500 off**:

Do this. Register and reach step 3 as a brand-new visitor.

Expect

- The quote **and** the charge both carry the offer. The wizard once printed the category price while checkout silently applied the offer behind it, so a patient owed ₹1,499 read "Pay ₹1,999 Now" and watched a different figure open in the sheet. **P0**.
- The visitor is **not asked for the offer and cannot send it** - eligibility is "has this patient ever paid", asked of the database.
- With the offer at **100%**, the total is **zero**, there is **no gateway order at all**, and **no ₹1 is charged**. A clinic advertising a free first session charging ₹1 is a **P0**.

VI-16 - A promo code, typed by a stranger · P0

With **QALaunch** at 20% and promo codes on:

Do this. At step 3, type the code.

Expect

- The quote says **what it takes off**, and **the request carries no amount** - check the Network tab. **A browser-sent figure is a P0**; the code is an identifier and every number comes from the row an admin created.
- Type a nonsense code: refused, saying so.
- Type a **paused** or **expired** one: it does nothing, and **says which**.
- Turn promo codes **off** and reload: the code field is **gone**. A code field with no campaign behind it teaches every patient there is a discount they are missing.

VI-17 - A home visit, and the address check · P1

Do this. From `/home-visit`, book the single visit.

Try	Expect
Enter pincode <code>560038</code>	Serviceable, travel quoted at ₹150
Enter <code>560025</code>	Not serviceable , said plainly, and the flow stops before an address is collected
Read the total	Programme plus travel , itemised - not the programme price on a button that charges more
Drop the connection and check a good pincode	"We could not check" , not "we do not visit your address". A failed lookup reported as unserviceable is a P1
Check twenty pincodes in a row	You are held off , with a message carrying no numbers and no blame , and a measured wait

VI-18 - A multi-visit home package cannot be bought directly · P0

Do this. In the console, try to create an order for the **four-visit** package:

```
const r = await fetch("/api/home-visit/create-order", {
  method: "POST",
  headers: { "Content-Type": "application/json" },
  body: JSON.stringify({ packageId: "PASTE_THE_4_VISIT_ID" }),
});
({ status: r.status, body: await r.text() });
```

Expect a refusal. A single visit is a consultation; two or more is a programme, and a programme comes from a care plan. **A 200 is a P0**.

Try `/api/home-visit/book-cash` with the same package: **also refused**. Paying at the door is a payment method, not a different product.

VI-19 - A stale `?package=` link is answered, not ignored · P1

Do this. Open `/book?package=SOME_OLD_ID` and `/book-home-visit?package=...`.

Expect. The wizard **says something** about it rather than silently selling you a single consultation. **Taking a different amount of money than somebody came for is the one outcome a removed checkout must not produce.**

VI-20 - Asking for a named specialist · P2

Do this. From `/team`, use the control that books a named therapist. Then edit the URL to name a therapist who is **hidden** from `/team`.

Expect

- The first: a chip naming that therapist, carried into the booking as a **request**.
- **It is never worded as a confirmed booking**. Only the admin can see whether that therapist is free for the slot. **"Your session with X is confirmed" is a P1**.
- The second: the request is **dropped silently** and the booking proceeds. It does not fail, and it does not name somebody the public cannot see.

5. Registering without booking

VI-21 - `/patient/register` waits on a human · P1

Do this. Register a patient at `/patient/register` with no booking.

Expect

- You are **signed in immediately** - again, no email-confirmation step.
- You land on ``/pending-approval``, and stay there until an admin approves you.
- That is deliberate: auto-approval exists for **genuine payment intent**, and a bare signup must not be a free way to skip the queue.

VI-22 - `/therapist/register` the same · P1

Register a therapist with no booking: signed in immediately, then `/pending-approval`, and **not** on `/team`.

VI-23 - The referral registration link · P1

Do this. With a hospital referral assigned a slot, open the registration link **in a private window**.

Expect

- The screen says **registration link**, never "invite link".
- It carries the patient's details forward.
- Setting a password lands them in their dashboard with the agreed session there.
- Open it **again**: it does not create a second account.
- Mangle the token: refused, saying the link is not valid.
- **Drop the connection and open a good link**: it says "**we could not check**", not "**this link has expired**". **A good link reported as expired is a P1** - it sends a patient to ring the hospital about a link that works.

6. The public doors, knocked on

VI-24 - Every public route is rate limited · P1

In a private window with no session, hammer each of these:

```

async function hammer(route, body, n = 25) {
  const out = [];
  for (let i = 0; i < n; i++) {
    const r = await fetch(route, {
      method: "POST",
      headers: { "Content-Type": "application/json" },
      body: JSON.stringify(body),
    });
    out.push(r.status);
  }
  return { route, statuses: out.join(",") };
}
console.table([
  await hammer("/api/hospitals/inquiry", { name: "QA", email: "qa@example.test" }),
  await hammer("/api/home-visit/check-area", { pincode: "560038" }),
  await hammer("/api/hospital/verify-code", { code: "QAHOSPA" }),
  await hammer("/api/appointments/quote", { categoryId: "PASTE_ONE" }),
]);

```

Expect

- Each one starts refusing with **429** after its own allowance.
- **One flow's allowance is not another's.** Exhausting the referral-code door must leave the area lookup working: a partner checking codes must not spend the allowance a patient needs to find out whether the clinic visits their street. **A shared bucket is a P1.**
- The refusal carries **no numbers** and **no blame**, and the wait is specific because it is measured.
- **A refused request still counts**, or somebody who keeps trying holds their own window open.

VI-25 - A 429 is never read as a "no" - P0

This is the rule that matters most in this section.

Do this. Exhaust the area-lookup allowance, then immediately go to a booking screen and enter a **serviceable** address.

Expect. The screen says **it could not check**, and the pay button is not disabled with a sentence saying the clinic does not visit that address.

Then the same for the referral code: exhaust `verify-code`, then open a **valid** registration link.

Expect. It says **it could not check**, never **"expired"**.

Both of these are P0s in the direction that matters: they tell a patient holding a good link or living at a serviceable address that the clinic has refused them, over a limiter that simply could not answer. A route whose 200 body carries a boolean cannot be read without checking the status first, and the honest third state is "we could not ask" rather than a falsy one.

VI-26 - A malformed body is a 400, never a 500 - P1

In a private window, send rubbish to every public POST:

```

const routes = [
  "/api/hospitals/inquiry",
  "/api/home-visit/check-area",
  "/api/hospital/verify-code",
  "/api/appointments/quote",
  "/api/patient/register-via-referral",
  "/api/razorpay/create-order",
  "/api/razorpay/verify",
];
const bodies = [{"", "null", "[]", '"hello"', ""};
for (const route of routes) {
  for (const body of bodies) {
    const r = await fetch(route, {
      method: "POST",
      headers: { "Content-Type": "application/json" },
      body,
    });
    if (r.status >= 500) console.log("500:", route, JSON.stringify(body));
  }
}
console.log("done - anything logged above is a defect");

```

Expect nothing logged. A malformed body is the caller's mistake, so the honest answer is **400**. **A 500 is a P1**: it means the body was parsed before anything checked it, and `null`, `[]` and a bare string are the three that slip past a naive check and arrive as a crash further down.

VI-27 - The admin surface, from outside · P0

```

const routes = [
  "/api/admin/approve-account",
  "/api/admin/create-account",
  "/api/admin/delete-account",
  "/api/admin/set-admin-scope",
  "/api/admin/settle-therapist-payout",
  "/api/admin/refund-session-partial",
  "/api/admin/grant-session-credits",
  "/api/admin/apply-goodwill-discount",
  "/api/admin/clear-activity-log",
  "/api/admin/activity-log",
  "/api/admin/start-impersonation",
  "/api/admin/update-setting",
  "/api/admin/debug-reset",
  "/api/admin/mark-paid-by-cash",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));

```

Expect 401 or 403 on every one, and never a 500. Any 200 is a P0 that stops the run.

`debug-reset` in particular. With the flag unset in the server environment it must answer **404**, not 403 - the route does not exist as far as a stranger is concerned.

VI-28 - The other roles' doors, from outside · P0

```
const routes = [
  "/api/therapist/reveal-contact",
  "/api/therapist/record-cash-collection",
  "/api/therapist/suggest-session",
  "/api/patient/condition-profile/export",
  "/api/patient/respond-suggestion",
  "/api/hospital/withdraw-referral",
  "/api/appointments/complete-session",
  "/api/appointments/confirm-free",
  "/api/medical-documents/view",
];
console.table(await Promise.all(routes.map(async (route) => {
  const r = await fetch(route, {
    method: "POST",
    headers: { "Content-Type": "application/json" },
    body: "{}",
  });
  return { route, status: r.status, body: (await r.text()).slice(0, 90) };
})));
```

Expect a refusal on every one.

``medical-documents/view`` is the sharpest. A scan report is the most sensitive thing this product holds, and its bucket is private precisely so the object URL is not the only secret. **A 200 here is a P0 that stops the run.**

``confirm-free`` is the second. It is the route that books a session for nothing when a discount takes the total to zero. **An anonymous 200 would be a way to book anything for free.**

VI-29 - What a database query can reach · P0

The public pages read the database with an anonymous key, so some tables are readable by anybody. Confirm which.

In a private window, from a page of the app:

Try to read	Expect
The treatment categories	Readable. They are on the public pages
The therapist public profiles	Readable - and containing no phone number and no email address
<code>promo_codes</code>	Nothing. A patient who can list it reads every campaign the clinic has ever scheduled, including the ones not yet running. P0
<code>appointments</code>	Nothing
<code>profiles</code>	Nothing beyond your own, and you have none
<code>patient_condition_profiles</code> , <code>pain_assessments</code> , <code>session_notes</code>	Nothing. P0
<code>admin_activity_log</code>	Nothing. P0
<code>payments</code>	Nothing. P0

VI-30 - The functions that mint things · P0

Some database functions move money or create sessions. None of them may be callable by a stranger holding the public key.

Do this. In a private window, attempt to call each of these through the database's own API:

`record_payment_capture`, `grant_session_credits`, `adjust_session_credits`, `void_session_credits`,
`claim_promo_code`, `claim_invite`, `purge_admin_activity_log`, `debug_reset_all_data`,
`revoke_user_sessions`.

Expect a permission error on every one.

This is the single most serious check in this document. Eleven of these were once callable over the public API by anybody holding the publishable key - no account needed - because the revoke naming only two roles left a third's grant in place. The statement succeeded, the permissions changed, and nothing was protected. **Any one of these executing is a P0 that stops the run immediately.**

7. Where a visitor is sent

VI-31 - The back office is never named · P0

Try	Expect
Open <code>/admin/dashboard</code> signed out	The sign-in screen or a bounce - never a rendered dashboard
Open <code>/admin/dashboard</code> signed in as a patient	Redirected to <code>/get-started</code> . Never to <code>/admin/login</code>
View <code>/admin/login</code> 's source	<code>noindex</code>
Search every public page's markup for <code>/admin</code>	Only the debug bar , which is removed at launch
Call <code>/api/admin/stop-impersonation</code> anonymously	The body says <code>/dashboard</code> - never <code>/admin/dashboard</code> and never <code>/admin/login</code>

A response body naming the back office is a P1. Check what a route says as well as what it lets you do: that route runs no admin check by design, so its refusal branches are reachable by anybody.

VI-32 - `/dashboard` resolves the role server-side · P1

Do this. Open `/dashboard`.

As	Expect
A stranger	<code>/get-started</code>
A patient	their dashboard
An unapproved patient	<code>/pending-approval</code>
A suspended one	<code>/account-suspended</code>

Expect. The admin path is **never** in a public bundle. Search the page source: no client component maps a role to `/admin/dashboard`.

VI-33 - The navbar's one button · P1

Do this. Signed out, then signed in as each of: an approved patient, an unapproved one, a suspended one.

State	The navbar should show
Signed out	Sign In and Get Started
Approved	Go to Dashboard , linking to <code>/dashboard</code>
Unapproved	Approval pending , linking to <code>/pending-approval</code>
Suspended	Account suspended , linking to <code>/account-suspended</code>

Expect

- **The label names the real destination.** A button reading "Go to Dashboard" that opens a waiting screen is telling somebody they did something they did not do: **P2**.
- **Nobody signed in is left with nothing.** Sign In is hidden the moment somebody is signed in, so whatever replaces it is their only route back into the app. **A signed-in visitor with no Sign In and no button at all is a P1** - and it is exactly what an unapproved account used to get.
- While it is still working out which, it shows **nothing** rather than briefly showing the wrong thing.
- On `/pending-approval` and `/account-suspended` the button is **absent** - it must not point at the page it is on.

VI-34 - The booking wizard's way out · P2

Do this. Open `/book` signed out, then signed in as a patient.

State	The exit link should read
Signed out	Back to Home (or Back to Home Visit on the other wizard)
Signed in	Back to Dashboard , going there

A patient who came from their own dashboard to book was being sent to the public home page: **P2**.

VI-35 - The splash greets a cold open and nothing else · P1

Do	Expect
Open the site in a fresh tab	The teal sheet, then the page
Navigate between pages	No splash
Reload	No splash
Switch tabs and come back within a minute	No splash
Leave the tab for longer than the away threshold and return	The splash
Ask for reduced motion	No splash at all

Expect. It appears **before** the page is readable, not on top of a page you can already read - which looks like a fault.

The case that matters: a patient paying by UPI leaves the tab for their bank's app and comes back mid-checkout. **A splash over a payment in progress is a P1.**

8. Across every page

VI-36 - Dates, money and the clinic's clock · P1

Check	Expect
Every date and time	India Standard Time , whatever your machine is set to
A session slot in the wizard	Built in your local time, with the detected timezone stated on screen
Money	Rupees. The word "paise" appears nowhere
A price that an admin changed a moment ago	Live immediately , not in five minutes

Set your machine to a different timezone and reload. A session for 6 PM IST that prints as 12:30 PM is a **P1**, and it is invisible to anybody testing in India.

VI-37 - On a phone · P2

Do this. Run `VI-01`, `VI-08` and `VI-13` again at phone width.

Expect

- No horizontal scrolling on any of the eight pages.
- Tap targets are reachable with a thumb.
- The booking wizard is usable start to finish.
- The dialogs fill the screen sensibly rather than shrinking.

VI-38 - Readability and keyboard · P2

Check	Expect
Small grey text on white	Readable. A label or hint you have to lean in for is a P2
Tab through a page	Focus is visible and follows the reading order
Every icon-only control	Has an accessible name
Every image	Has alt text describing the picture , not repeating the page's own blurb
A dialog	Escape closes it, Tab is trapped, focus returns, the page behind does not scroll

VI-39 - Security headers · P1

Do this. In the Network tab, open any public page and read the response headers.

Expect all of: `X-Frame-Options: DENY`, `X-Content-Type-Options`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy`, and HSTS.

Then try to frame a page from a scratch HTML file.

Expect. It refuses. Without this, the patient's health profile and the admin dashboard are framable by any site, and an appointment id in a URL travels as a full referrer to third parties. **A missing `X-Frame-Options` is a P1.**

A **report-only** content security policy is expected and correct. It must not be enforcing: Razorpay's checkout injects its own script and iframe, and a policy written blind takes down checkout.

VI-40 - An error page does not leak - P1

Do this. Open a nonsense URL, and a detail route with an invalid id.

Expect. A **reference code and nothing else** - no column name, no row id, no stack trace. Patients see these screens. **A thrown message on screen is a P1.**

9. Sign-off

	Should be
Steps run	40
Pass	
Fail	
Blocked	
N/A	
P0 raised	
P1 raised	

Confirm each of these before signing.

All eight pages open, read as one site, and end the same way	☐
Every photograph shows a device and a face, in the cropped file	☐
Every rail entry matched a section that rendered, in order	☐
Every Explore band ended on booking, with its rows squared up	☐
No programme price on any public page, and no setting to bring one back	☐
A stranger registered and paid on one screen, with no email-confirmation step	☐
The figure on the button matched the figure in the payment sheet	☐
A 100% discount was free, not ₹1	☐
A promo code was sent as a name and never as an amount	☐
An unserviceable address refused; a failed lookup not reported as unserviceable	☐
A 429 was never read as "invalid" or "expired"	☐
A multi-visit home package could not be bought directly	☐
Every public route rate limited, with separate allowances per flow	☐
Every malformed body answered 400, never 500	☐
401 or 403 on every admin route; <code>debug - reset</code> answered 404	☐

Nothing readable from the database beyond the public pages' own content	☐
Every money-moving database function refused	☐
The back office was never named, in a page or in a response body	☐
A signed-in account always had a button, and the label named the real page	☐
The splash greeted a cold open and nothing else	☐
Security headers present, and framing refused	☐

Signed **Date**

Build / commit tested

What a clean run of this document proves. That what a stranger can see, buy and reach behaved on one machine, in one browser, against test payment keys, once. It does not prove the signed-in journeys behind those doors - each role has a document of its own - and it does not cover real payment processing, email or SMS delivery, search engine behaviour, load, or other browsers. Those are not covered here and a clean run should not be read as covering them.